USCS - Universidade Municipal de São Caetano do Sul
Ciência da Computação
Tópicos Avançados - ENADE

Material de Estudos de Segurança da Informação

Enrico Nalini Genaro
Giovani Maia Tirapani
Giovanna Santos Silva
Murilo Vinicius de Faveri
Rafael Platero Brandani
Thais Gabriel
424-08AN
SQUAD 4

São Caetano do Sul
23/09/2026

Material de Estudos de Segurança da Informação
Preparação detalhada para o ENADE de Ciência da Computação



Mapa geral do conteúdo desenvolvido nesta apostila

Giovanna Santos Silva
Ciência da Computação • USCS • 2026

Material elaborado a partir da matriz do ENADE, das provas e dos gabaritos oficiais de 2017 e 2021, com complementação por normas e guias oficiais.

Como usar este material

Esta apostila organiza Segurança da Informação como conhecimento técnico e como competência profissional. O objetivo não é apenas memorizar definições. Ao final, o estudante deve reconhecer ativos, ameaças e vulnerabilidades; estimar riscos; escolher controles; justificar decisões; avaliar consequências técnicas, legais e éticas; e relacionar segurança com outras áreas da Computação.

Estratégia recomendada Estude cada unidade em três passagens: primeiro os conceitos; depois os exemplos e esquemas; por fim as questões. Ao corrigir um erro, registre qual conceito faltou e por que a alternativa escolhida parecia correta.

Organização pela matriz curricular

Unidade	Tópicos centrais	Competências praticadas
1 Fundamentos e riscos	Princípios, ativos, ameaças, vulnerabilidades, risco, controles e dependabilidade	Identificar, classificar, analisar e justificar
2 Criptografia, identidade e acesso	Cifras, hash, assinatura, certificados, autenticação, autorização e auditoria	Comparar mecanismos e selecionar proteção
3 Redes, sistemas, aplicações e dados	Ataques de rede, protocolos, hardening, malware, segurança de software, bancos e nuvem	Projetar, implementar, testar e monitorar
4 Gestão, resposta, continuidade e legislação	Governança, políticas, incidentes, continuidade, LGPD, ética e privacidade	Gerenciar riscos, responder e avaliar impactos

Mapa de cobertura da matriz

Tema exigido	Onde aparece
Confidencialidade, integridade e disponibilidade	Capítulos 1, 2, 8 e revisões
Autenticidade e autenticação	Capítulos 1, 4 e 5
Controle de acesso	Capítulo 5
Criptografia	Capítulo 4
Vulnerabilidades, ameaças e riscos	Capítulos 2 e 3
Proteção de sistemas	Capítulos 6 e 7
Dependabilidade	Capítulo 2 e capítulo 10
Ética e legislação	Capítulo 9
Correlações com outras matérias	Capítulo 10
Competências e questões do ENADE	Capítulos 11 a 13

Referencial curricular e teórico

A seleção de conteúdos parte das Diretrizes Curriculares Nacionais da área de Computação, da Portaria Inep nº 401 de 2021 e das provas do ENADE de 2017 e 2021. O aprofundamento técnico usa o NIST Cybersecurity Framework 2.0, publicações especiais do NIST, a família ISO IEC 27000, normas criptográficas FIPS, documentos do IETF, orientações da CISA, materiais da OWASP, a LGPD e guias da ANPD. As referências completas estão no final.

Unidade 1 - Fundamentos e riscos

1. Segurança da Informação

Segurança da Informação é a preservação do valor da informação contra eventos acidentais ou intencionais. Ela envolve pessoas, processos, tecnologia e ambiente físico. Por isso, instalar um antivírus não encerra o problema: um sistema pode falhar por configuração inadequada, credencial roubada, erro humano, incêndio, dependência externa ou decisão de gestão.

Informação e dado Dado é uma representação bruta, como "37,8". Informação surge quando há contexto, por exemplo "temperatura do servidor: 37,8 °C". A segurança protege ambos, mas o impacto é avaliado pelo valor que possuem para uma pessoa ou organização.



Figura 1 Princípios fundamentais da Segurança da Informação

Princípio	Pergunta de diagnóstico	Exemplos de controle
Confidencialidade	Somente pessoas e sistemas autorizados acessam o conteúdo?	Criptografia, classificação, mínimo privilégio
Integridade	É possível detectar ou impedir alteração indevida?	Hash, assinatura, validação, controle de versão
Disponibilidade	O serviço e os dados estão acessíveis quando necessários?	Redundância, backup, monitoramento, capacidade
Autenticidade	A identidade e a origem são genuínas?	Certificados, assinatura digital, MFA
Responsabilização	É possível atribuir ações a uma entidade?	Logs protegidos, contas individuais, trilha de auditoria

Não repúdio	Há evidência que dificulte negar uma ação realizada?	Assinatura digital, carimbo de tempo e evidências íntegras

Exemplo integrado Um prontuário criptografado atende à confidencialidade. Um hash ou assinatura ajuda a verificar a integridade. Réplicas e restauração testada sustentam a disponibilidade. MFA confirma melhor a identidade do profissional. Logs registram quem visualizou ou alterou o prontuário.

2. Ativos, ameaças, vulnerabilidades e controles

Conceito	Definição operacional	Exemplo
Ativo	Algo que tem valor e precisa ser protegido	Dados pessoais, reputação, servidor, chave privada
Ameaça	Fonte ou evento capaz de causar dano	Criminoso, malware, enchente, erro de operador
Vulnerabilidade	Fraqueza que pode ser explorada	Senha padrão, software desatualizado, porta exposta
Evento	Ocorrência observável, ainda sem concluir que houve dano	Muitas tentativas de login
Incidente	Evento que compromete ou ameaça políticas e operações	Conta invadida e usada para extrair dados
Controle	Medida que modifica o risco	MFA, segmentação, treinamento, backup
Risco	Efeito da incerteza sobre objetivos, considerando probabilidade e impacto	Interrupção do serviço após ransomware

A cadeia causal pode ser lida assim: uma ameaça explora uma vulnerabilidade, produz um evento adverso e causa impacto sobre um ativo. Um controle preventivo reduz a probabilidade; um controle detectivo reduz o tempo até a descoberta; um controle corretivo ou de recuperação limita o impacto e restaura a operação.

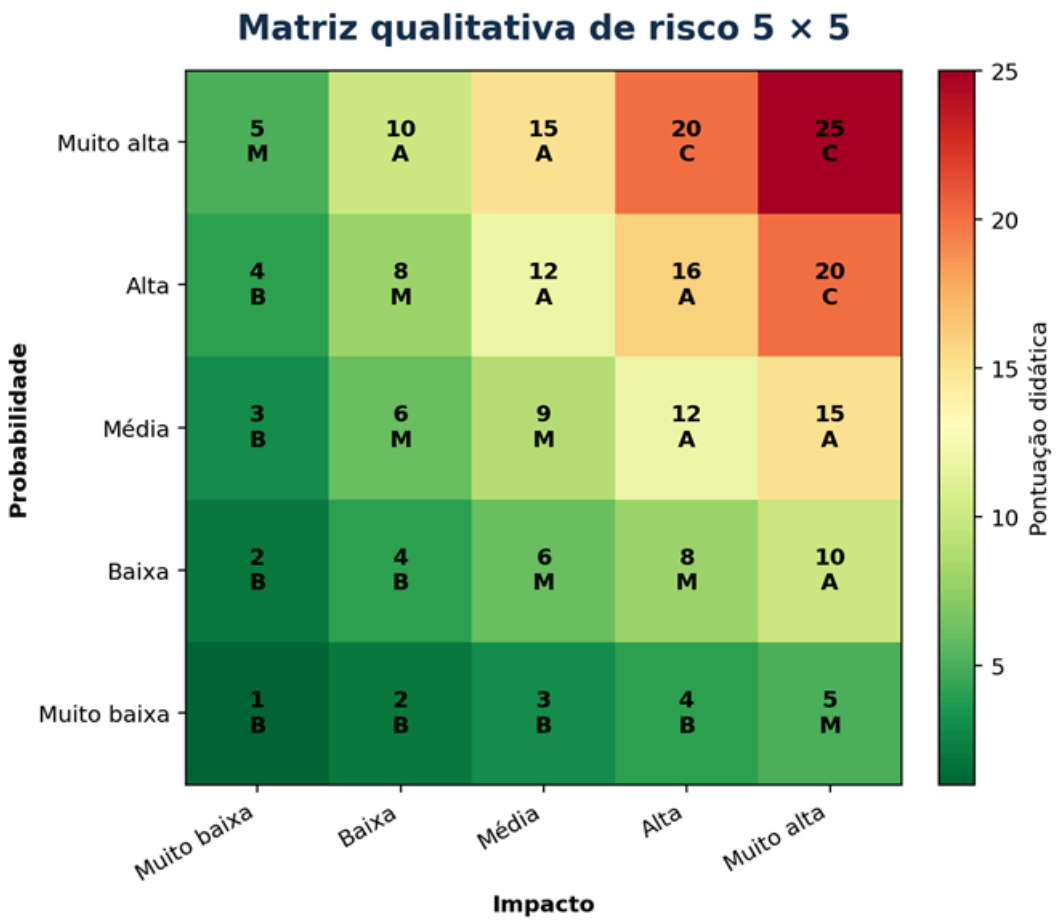


Figura 2 Exemplo didático de matriz de risco B baixo M médio A alto C crítico

A multiplicação probabilidade × impacto é uma técnica de priorização, não uma verdade matemática universal. As escalas precisam ter critérios claros. Um risco raro pode continuar inaceitável se o impacto envolver vidas, direitos fundamentais ou interrupção crítica.

Risco inerente e residual Risco inerente é estimado antes dos controles considerados. Risco residual permanece depois dos controles. A direção deve decidir se aceita, reduz, evita ou transfere esse risco dentro de limites definidos.

Exemplo de análise de risco

Etapa	Aplicação em um sistema acadêmico
Contexto	Portal armazena notas, documentos e dados pessoais
Ativo	Banco de dados de estudantes
Ameaça	Criminoso usa credenciais obtidas por phishing
Vulnerabilidade	Ausência de MFA e alertas de login anômalo
Impacto	Exposição de dados, fraude e indisponibilidade
Controles	MFA resistente a phishing, detecção, limite de sessão, treinamento
Evidência	Logs centralizados, testes, métricas de bloqueio e restauração
Risco residual	Reavaliado após medir efetividade dos controles

3. Classificação de controles

Dimensão	Categorias	Exemplos
Finalidade	Preventivo, detectivo, corretivo, recuperativo, dissuasório, compensatório	MFA; SIEM; patch; restauração; aviso; revisão manual
Natureza	Administrativo, técnico, físico	Política; firewall; controle de acesso à sala
Momento	Antes, durante e depois do evento	Hardening; detecção; resposta e lições aprendidas
Responsabilidade	Pessoa, processo, tecnologia ou terceiro	Treinamento; mudança; EDR; cláusula contratual



Figura 3 Defesa em profundidade

Defesa em profundidade não significa acumular ferramentas sem coordenação. As camadas precisam cobrir caminhos de ataque diferentes, gerar evidências e evitar dependência de um único ponto de falha. Controles duplicados que falham pelo mesmo motivo oferecem pouca independência.

4. Dependabilidade e resiliência

A matriz do curso associa segurança à dependabilidade. Dependabilidade expressa o grau de confiança de que um sistema prestará o serviço esperado. Ela se relaciona a disponibilidade, confiabilidade, integridade, manutenibilidade e, em sistemas críticos, segurança contra danos. Resiliência é a capacidade de preparar-se, resistir, responder e recuperar-se mantendo objetivos essenciais.

Medida	Interpretação	Exemplo
MTBF	Tempo médio entre falhas	Quanto maior, menos frequentes as falhas observadas
MTTR	Tempo médio para restaurar ou reparar	Quanto menor, mais rápida a recuperação
Disponibilidade	MTBF dividido por MTBF + MTTR em modelo simplificado	MTBF 99 h e MTTR 1 h resultam em 99%
RTO	Tempo máximo desejado para restaurar serviço	Portal deve voltar em até 4 horas
RPO	Perda máxima de dados expressa em tempo	No máximo 15 minutos de transações

Armadilha comum Backup não prova recuperabilidade. É preciso definir RPO e RTO, proteger cópias contra o mesmo ataque e testar restaurações. Redundância melhora disponibilidade, mas não substitui backup quando dados íntegros precisam ser recuperados.

Unidade 2 Criptografia identidade e acesso

5. Fundamentos de criptografia

Criptografia transforma informação para atender objetivos como confidencialidade, integridade, autenticidade e não repúdio. O algoritmo pode ser público; a segurança deve depender da proteção das chaves. Um projeto seguro também precisa de geração aleatória adequada, armazenamento, rotação, revogação, cópia de segurança e descarte de chaves.



Figura 4 Comparação entre mecanismos criptográficos

Mecanismo	O que oferece	O que não garante sozinho	Uso típico
AES	Confidencialidade; com modo autenticado, integridade	Identidade do usuário e gestão automática de chaves	Dados em repouso e sessões
Criptografia assimétrica	Troca de segredo, assinatura ou cifragem conforme o esquema	Disponibilidade e confiança na chave pública	Certificados, assinatura e estabelecimento de chaves
Hash criptográfico	Resumo de tamanho fixo e detecção de mudança	Confidencialidade, autoria ou reversão	Integridade, assinatura, identificação de conteúdo
HMAC	Integridade e autenticidade entre quem compartilha segredo	Não repúdio perante terceiros	APIs e protocolos
Assinatura digital	Integridade, autenticidade e	Confidencialidade do conteúdo	Documentos e atualização de software

	evidência vinculada à chave privada		

5.1 Criptografia simétrica

Na criptografia simétrica, remetente e destinatário usam a mesma chave secreta ou chaves diretamente relacionadas. O AES é uma cifra de bloco padronizada pelo NIST com blocos de 128 bits e chaves de 128, 192 ou 256 bits. O tamanho da chave não é o único fator: modo de operação, nonce ou IV, autenticação, implementação e gestão de chaves são decisivos.

IV e nonce Um vetor de inicialização ou nonce impede que mensagens iguais produzam padrões previsvisíveis em modos apropriados. Ele nem sempre precisa ser secreto, mas os requisitos de unicidade ou imprevisibilidade dependem do modo. Reutilizá-lo onde a especificação proíbe pode comprometer confidencialidade e integridade.

5.2 Criptografia assimétrica certificados e PKI

Na criptografia assimétrica, a chave pública pode ser divulgada e a chave privada deve permanecer sob controle do titular. Para assinatura, a chave privada produz a assinatura e a pública verifica. Para cifragem, o papel das chaves depende do esquema. Certificados digitais vinculam uma identidade a uma chave pública por meio de uma autoridade certificadora e de uma cadeia de confiança.

1. O cliente recebe o certificado do servidor.
2. Valida nome, período, finalidade, assinatura da autoridade e estado de confiança.
3. As partes negociam segredos de sessão.
4. A comunicação passa a usar criptografia autenticada eficiente.

Não confunda Cifrar com a chave pública do destinatário visa confidencialidade. Assinar com a chave privada do remetente visa autenticidade e integridade. “Criptografar com a chave privada” não é uma explicação geral adequada para assinatura digital.

5.3 Hash senhas e derivação de chaves

Funções hash como SHA-256 geram resumos usados para detectar alterações. Entretanto, armazenar senhas com SHA-256 puro é inadequado porque atacantes podem testar bilhões de candidatos. Senhas devem passar por função de derivação lenta e parametrizável, com salt único por credencial. O salt não precisa ser secreto; ele impede que senhas iguais tenham o mesmo resultado e reduz o valor de tabelas pré-computadas.

Termo	Função

Salt	Valor único armazenado junto ao verificador; dificulta pré-computação
Pepper	Segredo adicional mantido separado do banco, quando adotado
KDF de senha	Eleva custo de cada tentativa; exemplos incluem Argon2id, scrypt, bcrypt e PBKDF2
Hash comum	Adequado para integridade, não para proteger senhas sozinho

5.4 TLS e proteção em trânsito

TLS protege comunicação cliente-servidor contra escuta, alteração e falsificação de mensagens. A versão 1.3 corrente é especificada pelo RFC 9846, que substituiu o RFC 8446 em 2026. O ENADE 2017 usou a ideia de TLS e certificados para discutir autenticação e negociação de chaves em um cenário de ataque de homem no meio.

Limite do TLS TLS protege o canal entre extremidades autenticadas. Se o próprio endpoint estiver comprometido, se o usuário aceitar certificado inválido ou se a aplicação registrar dados sensíveis em texto claro, o canal seguro não resolve o problema.

6. Identificação autenticação autorização e auditoria

Etapa	Pergunta	Exemplo
Identificação	Quem afirma ser?	E-mail ou identificador de usuário
Autenticação	Como prova a identidade?	Senha + chave de segurança
Autorização	O que pode fazer?	Professor altera notas apenas de suas turmas
Auditoria	O que fez e quando?	Log assinado de alteração de nota
Accountability	A ação pode ser atribuída de modo confiável?	Conta individual, relógio sincronizado e logs protegidos

Fatores de autenticação incluem algo que a pessoa sabe, possui ou é. Dois passos do mesmo fator não constituem MFA genuíno. Senha e PIN são ambos conhecimento; senha e aplicativo autenticador combinam conhecimento e posse. Biometria exige cuidado com falsos positivos, acessibilidade, apresentação coercitiva e impossibilidade prática de “trocar o dedo” após vazamento.

Método	Resistência a phishing	Riscos principais	Uso recomendado
Senha	Baixa	Reuso, vazamento, captura	Com gerenciador, bloqueios e MFA
Código por SMS	Baixa a média	SIM swap, redirecionamento, phishing	Melhor que senha isolada, mas não preferencial
TOTP	Média	Código pode ser capturado em tempo real	MFA amplamente compatível

Push simples	Média	Fadiga de aprovação	Usar contexto e number matching
FIDO2 WebAuthn	Alta	Perda do autenticador e recuperação mal projetada	Preferível para contas de maior risco
Biometria local	Depende do protocolo	Spoofing, privacidade e recuperação	Desbloquear chave protegida no dispositivo

A CISA recomenda priorizar MFA resistente a phishing. A revisão 4 das Diretrizes de Identidade Digital do NIST separa prova de identidade, autenticação e federação e exige que o nível de garantia seja proporcional ao risco.

6.1 Modelos de controle de acesso

Modelo	Decisão baseada em	Ponto forte	Limitação
DAC	Proprietário do recurso	Flexibilidade	Propagação excessiva de permissões
MAC	Rótulos e política central	Controle rígido	Menor flexibilidade
RBAC	Papéis organizacionais	Administração simples	Explosão de papéis
ABAC	Atributos de sujeito, recurso, ação e contexto	Decisão granular e dinâmica	Políticas mais complexas
ReBAC	Relações entre entidades	Natural para grafos sociais e colaboração	Análise e auditoria exigentes

Mínimo privilégio Conceda somente as permissões necessárias, pelo tempo necessário e no contexto necessário. Separe funções incompatíveis, revise acessos e revogue-os quando o vínculo mudar.

Zero Trust não significa desconfiar de pessoas. Significa não conceder confiança implícita apenas pela localização de rede. Cada acesso deve considerar identidade, dispositivo, recurso, contexto, política e sinais de risco, com verificação contínua e privilégio mínimo (NIST SP 800-207).

Unidade 3 Redes sistemas aplicações e dados

7. Segurança de redes e comunicações

A segurança de rede controla fluxos, reduz superfície de ataque, separa domínios de confiança e produz visibilidade. Endereçamento, roteamento, DNS, ARP, Wi-Fi e protocolos de aplicação tornam-se assuntos de segurança porque falhas nessas camadas permitem desvio, interceptação, falsificação ou indisponibilidade.

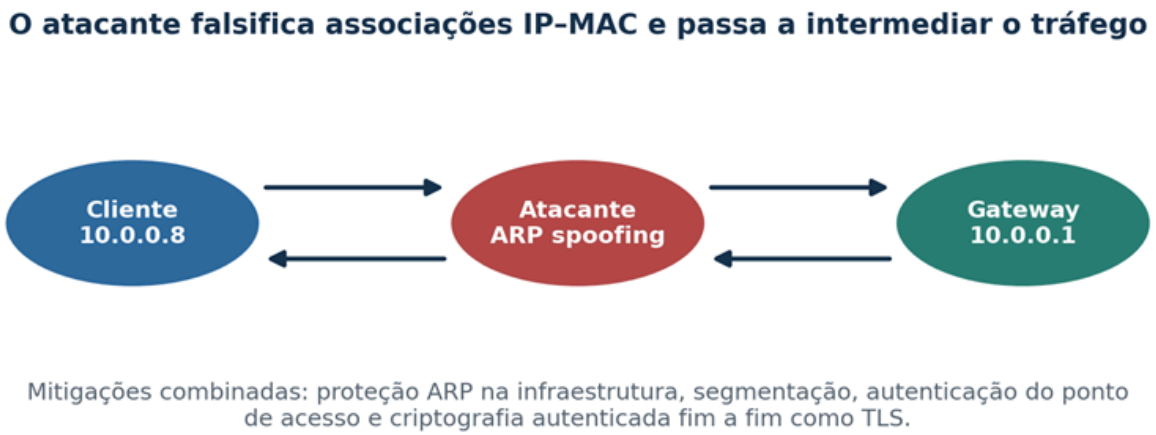


Figura 5 Ataque de homem no meio por falsificação ARP

Ataque	Mecanismo	Impacto	Mitigações combinadas
ARP spoofing	Respostas ARP falsas associam IP legítimo ao MAC do atacante	Intercepção e alteração local	DAI, segmentação, TLS, monitoramento
DNS spoofing	Resposta ou cache aponta nome para endereço malicioso	Phishing e desvio	DNSSEC onde aplicável, resolver seguro, TLS e validação
Evil twin	Ponto de acesso imita rede legítima	Roubo de sessão ou credencial	802.1X, certificados, orientação e VPN conforme risco
DoS e DDoS	Exaustão de banda ou recursos	Indisponibilidade	Capacidade, rate limit, CDN e resposta do provedor
Varredura	Descoberta de portas e serviços	Reconhecimento	Reduzir exposição, alertar e corrigir
Sequestro de sessão	Token é obtido ou fixado	Acesso como vítima	TLS, cookies seguros, rotação e expiração

Um firewall filtra tráfego conforme política, mas não autentica automaticamente um ponto de acesso, não corrige uma aplicação vulnerável e não impede toda comunicação entre dispositivos na mesma camada 2. A

questão 15 de 2017 explora exatamente a necessidade de escolher controles compatíveis com a causa do ataque.

7.1 Segmentação e arquitetura

Segmentar separa recursos por criticidade e função. Uma regra “negar por padrão” libera apenas fluxos necessários. DMZ, VLAN, microsegmentação e proxies são meios diferentes de criar limites. O desenho precisa considerar administração, DNS, atualizações, monitoramento e caminhos de contingência; caso contrário, exceções podem reabrir a superfície que se pretendia reduzir.



Figura 6 Funções do NIST Cybersecurity Framework 2.0

8. Sistemas operacionais endpoints malware e nuvem

Hardening reduz funções, serviços e permissões desnecessárias. Uma linha de base segura deve ser versionada, testada e monitorada contra desvios. Atualizações tratam vulnerabilidades conhecidas, mas precisam de inventário, prioridade, janela, teste e plano de reversão.

Área	Práticas essenciais
Contas	Remover padrões, impedir compartilhamento, MFA administrativo, privilégios separados
Serviços	Desativar o que não é necessário e limitar interfaces de escuta
Patches	Priorizar exploração ativa, exposição e criticidade do ativo
Logs	Centralizar, sincronizar tempo, proteger integridade e definir retenção
Endpoint	Antimalware ou EDR, criptografia de disco, bloqueio e controle de execução
Segredos	Não gravar em código; usar cofre, rotação e escopo mínimo
Backup	Cópias separadas, protegidas, versionadas e testadas

Tipo de código malicioso	Característica
Vírus	Anexa-se a outro arquivo e depende de execução para propagar
Worm	Propaga-se autonomamente por redes ou vulnerabilidades
Trojan	Apresenta-se como legítimo para executar ação maliciosa
Ransomware	Criptografa, bloqueia ou exfiltra para extorquir
Spyware e infostealer	Coleta dados, credenciais, cookies e carteiras
Rootkit	Oculta presença ou mantém privilégio
Bot	Integra o host a infraestrutura controlada remotamente

Em nuvem, o provedor protege parte da infraestrutura, enquanto o cliente continua responsável por identidades, configuração, dados e uso seguro conforme o modelo de serviço. “Está na nuvem” não é uma propriedade de segurança. O projeto deve esclarecer responsabilidade compartilhada, região, chaves, logs, continuidade, portabilidade e dependência do provedor.

9. Segurança de aplicações bancos de dados e cadeia de suprimentos

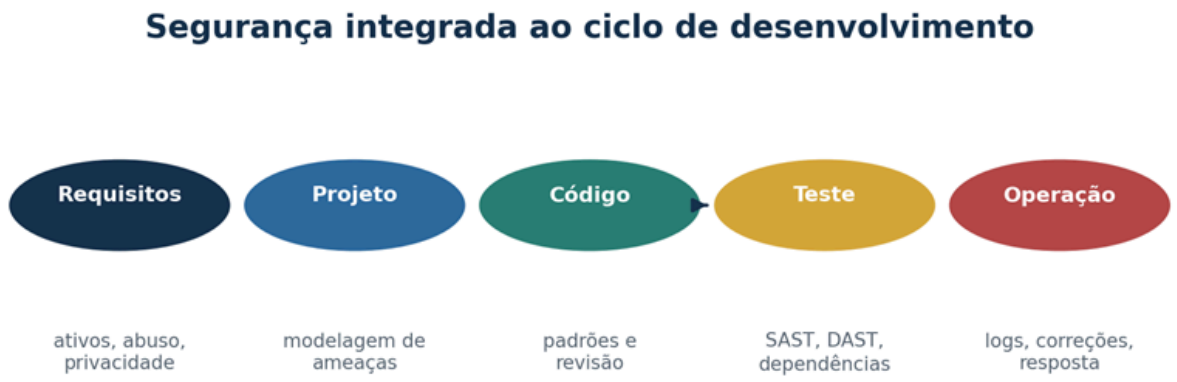


Figura 7 Segurança no ciclo de desenvolvimento

O NIST SSDF recomenda integrar práticas de desenvolvimento seguro ao ciclo já usado pela equipe. Requisitos de segurança, modelagem de ameaças, revisão, testes e resposta a vulnerabilidades devem gerar evidências rastreáveis. O OWASP Top 10 2025 funciona como documento de conscientização sobre riscos críticos de aplicações web, não como checklist completo de conformidade.

Risco de aplicação	Exemplo	Controle principal
Controle de acesso quebrado	Usuário altera o ID na URL e vê registro alheio	Autorização no servidor para cada objeto e ação
Configuração insegura	Painel administrativo exposto com padrão	Baseline, segredo seguro e revisão automatizada
Falha de cadeia de suprimentos	Dependência comprometida entra no build	Inventário, pinagem, assinatura, revisão e atualização
Injeção	Entrada muda o significado de comando SQL	Consultas parametrizadas e validação contextual
Falha criptográfica	Dados sensíveis em texto claro ou algoritmo inadequado	Bibliotecas aprovadas e gestão de chaves
Autenticação falha	Sessão longa, recuperação fraca ou token exposto	MFA, sessão segura e recuperação robusta
Logging insuficiente	Ataque ocorre sem evidência útil	Eventos definidos, proteção e alerta

Exemplo de SQL injection Concatenar “SELECT * FROM usuarios WHERE nome = ” + entrada mistura dados e comandos. Consultas parametrizadas enviam o valor separadamente, impedindo que a entrada altere a estrutura SQL. Escapar texto manualmente é mais frágil.

Bancos de dados exigem classificação, permissões por função, criptografia, integridade transacional, backup, auditoria e minimização. Criptografia de disco protege mídia perdida, mas não impede que uma aplicação autenticada e vulnerável leia os dados. Mascaramento ou tokenização pode reduzir exposição em testes e análise.

APIs devem autenticar o cliente, autorizar cada operação, limitar taxa e volume, validar esquema, proteger tokens, registrar eventos e evitar exposição excessiva. Tokens assinados, como JWT, não são necessariamente secretos: o conteúdo pode ser legível. Assinatura verifica integridade e emissor; confidencialidade exige cifragem ou outra proteção.

9.1 Modelagem de ameaças

Modelar ameaças antes da implementação ajuda a perguntar o que pode dar errado. Um processo simples inclui decompor a arquitetura, identificar ativos e limites de confiança, enumerar abusos, priorizar riscos e definir controles verificáveis. STRIDE organiza ameaças em falsificação, adulteração, repúdio, divulgação, negação de serviço e elevação de privilégio.

STRIDE	Propriedade ameaçada	Pergunta
Spoofing	Autenticidade	Alguém pode fingir ser outra entidade?
Tampering	Integridade	Dados ou código podem ser alterados?
Repudiation	Responsabilização	A ação pode ser negada por falta de evidência?
Information disclosure	Confidencialidade	Informação pode vazar?
Denial of service	Disponibilidade	O recurso pode ser exaurido?
Elevation of privilege	Autorização	Alguém pode obter capacidade maior que a permitida?

Unidade 4 Gestão resposta continuidade e legislação

10. Governança e Sistema de Gestão

Governança define direção, responsabilidades, apetite a risco e supervisão. Gestão transforma essa direção em processos, recursos e controles. A ISO IEC 27001 especifica requisitos para um Sistema de Gestão de Segurança da Informação baseado em risco e melhoria contínua. O NIST CSF 2.0 organiza resultados em Governar, Identificar, Proteger, Detectar, Responder e Recuperar.

Documento	Função	Exemplo
Política	Expressa direção e regras de alto nível	Todo acesso administrativo exige MFA
Norma interna	Define requisito obrigatório específico	Parâmetros mínimos de autenticação
Procedimento	Explica sequência operacional	Como revogar conta de desligado
Guia	Orienta boas práticas, com flexibilidade	Como reconhecer phishing
Registro e evidência	Demonstra execução e resultado	Ata de revisão, log, relatório de teste

Papéis devem ser definidos: proprietários de risco e ativos tomam decisões; segurança orienta e monitora; tecnologia implementa; auditoria avalia com independência; usuários cumprem políticas; fornecedores atendem obrigações contratuais. A responsabilidade não desaparece quando a execução é terceirizada.

10.1 Tratamento e monitoramento de riscos

Resposta	Quando faz sentido	Exemplo
Evitar	A atividade não compensa o risco	Retirar serviço legado da internet
Mitigar	Controles reduzem probabilidade ou impacto	MFA e segmentação
Transferir ou compartilhar	Outra parte assume parcela financeira ou operacional	Seguro e contrato, sem eliminar deveres legais
Aceitar	Risco residual cabe no apetite e é aprovado	Registrar decisão, prazo e responsável

Indicadores devem apoiar decisões. Exemplos: cobertura de MFA; tempo para corrigir vulnerabilidades críticas; percentual de restaurações testadas; tempo médio para detectar e responder; acessos vencidos; taxa de ativos inventariados. Uma métrica pode ser manipulada ou perder contexto, por isso deve ter definição, fonte, periodicidade, meta e responsável.

11. Gestão de incidentes

O NIST SP 800-61 Rev. 3 integra resposta a incidentes ao CSF 2.0. Preparação e governança reduzem improvisação; detecção e análise estabelecem o que aconteceu; contenção limita propagação; erradicação remove causa; recuperação restaura com segurança; lições aprendidas corrigem processos e controles.

5. Confirmar o evento e preservar evidências.
6. Classificar gravidade, ativos, dados e dependências afetadas.
7. Acionar papéis técnicos, jurídicos, comunicação e direção conforme plano.
8. Conter sem destruir evidências ou ampliar impacto.
9. Erradicar a causa, corrigir vulnerabilidades e trocar segredos comprometidos.
10. Recuperar em etapas, monitorar recaída e validar integridade.
11. Documentar decisões, comunicar quando exigido e acompanhar melhorias.

Cadeia de custódia Evidências digitais devem ter origem, coletor, data, método, hash, armazenamento e transferências registrados. Preservar evidência pode conflitar com restaurar rapidamente; o plano deve definir critérios e autoridade para a decisão.

12. Continuidade de negócios e recuperação

A Análise de Impacto no Negócio identifica processos essenciais, dependências e consequências da interrupção. Continuidade mantém operação mínima; recuperação de desastre restaura tecnologia; resposta a incidentes trata o evento de segurança. Os planos se conectam, mas não são sinônimos.

Estratégia	Vantagem	Cuidado
Backup completo incremental diferencial	Equilibra janela, armazenamento e restauração	Testar cadeia e tempo real de recuperação
Site frio	Baixo custo	Recuperação lenta e maior configuração
Site morno	Equilíbrio	Dados e capacidade precisam sincronização
Site quente	Retorno rápido	Custo e risco de replicar corrupção
Alta disponibilidade	Reduz falha de componente	Não corrige exclusão lógica ou ransomware

13. LGPD privacidade e ética

A LGPD disciplina o tratamento de dados pessoais em meio físico ou digital e protege liberdade, privacidade e desenvolvimento da personalidade.

Segurança e privacidade se sobrepõem, mas não são iguais: um tratamento pode ser tecnicamente seguro e ainda ser excessivo ou sem base legal; também pode ser legítimo, porém inseguro.

Conceito LGPD	Síntese para estudo
Dado pessoal	Informação relacionada a pessoa natural identificada ou identificável
Dado pessoal sensível	Inclui origem racial ou étnica, convicção religiosa, opinião política, saúde, vida sexual, genética ou biometria vinculada
Tratamento	Operações como coleta, uso, acesso, armazenamento, comunicação e eliminação
Controlador	Decide sobre o tratamento
Operador	Trata dados em nome do controlador
Encarregado	Canal entre agentes, titulares e ANPD conforme a lei e regulamentação
Anonimização	Uso de meios razoáveis disponíveis para retirar possibilidade de associação direta ou indireta
Pseudonimização	Substitui identificadores, mas permite reidentificação com informação adicional protegida

Princípios incluem finalidade, adequação, necessidade, livre acesso, qualidade, transparência, segurança, prevenção, não discriminação e responsabilização. Direitos do titular incluem confirmação de tratamento, acesso, correção e, nas condições legais, anonimização, bloqueio, eliminação e portabilidade.

Ponto cobrado em 2021 Dado que pode ser reidentificado com meios próprios ou esforços razoáveis não deve ser tratado automaticamente como anônimo. A ANPD fiscaliza e regulamenta dentro de sua competência, mas não “modifica a lei”.

Privacy by design incorpora privacidade desde requisitos e arquitetura. Práticas importantes: minimização, separação, transparência, retenção definida, controle pelo titular, segurança proporcional, testes e revisão de compartilhamentos. Consentimento é apenas uma das bases legais e não deve ser usado como resposta automática para qualquer tratamento.

Ética profissional exige avaliar danos, proporcionalidade, conflito de interesses, discriminação, transparência e efeitos sociais. A questão 16 de 2017 reforça que segurança é processo e que ética e comportamento humano integram o problema. Dizer que “o humano é sempre o elo mais fraco” simplifica em excesso: sistemas inseguros podem induzir erro, negar alternativas ou transferir responsabilidade ao usuário.

14. Relações com outras matérias da Computação

Área	Relação direta com segurança	Exemplo de questão integrada
Redes	Protocolos, endereçamento, roteamento, segmentação e disponibilidade	Analisar ARP spoofing e selecionar controles
Sistemas Operacionais	Processos, memória, permissões, isolamento e logs	Explicar elevação de privilégio
Banco de Dados	Transações, acesso, auditoria, backup e privacidade	Projetar acesso a prontuários
Engenharia de Software	Requisitos, arquitetura, testes, manutenção e cadeia de suprimentos	Inserir segurança no SDLC
Sistemas Distribuídos	Consenso, falhas parciais, identidade de serviços e relógios	Manter integridade sob falhas
Programação	Validação, memória, tipos, erros e bibliotecas	Evitar injeção e exposição de segredo
IHC	Mensagens, recuperação, consentimento e segurança utilizável	Projetar MFA acessível
IA e Dados	Envenenamento, evasão, privacidade, viés e cadeia de dados	Avaliar risco de modelo e dataset
Ética e Sociedade	Direitos, responsabilidade, impacto e legislação	Decidir tratamento proporcional de dados
Gestão de Projetos	Escopo, custos, prioridades e mudanças	Tratar risco e aceitar residual

14.1 Sistemas distribuídos e dependabilidade

Sistemas distribuídos falham parcialmente: um nó pode responder enquanto outro está indisponível; mensagens podem atrasar, duplicar ou chegar fora de ordem. Segurança exige autenticar serviços, proteger segredos, limitar repetição, lidar com idempotência, sincronizar tempo e manter observabilidade. Alta disponibilidade sem consistência pode servir dados incorretos; consistência sem redundância pode criar ponto único de falha.

14.2 Inteligência artificial

Sistemas de IA acrescentam riscos de dados, modelo, integração e uso. Exemplos: envenenamento de dados, entrada adversarial, extração de modelo, prompt injection em aplicações com LLM, vazamento por logs e confiança excessiva em saídas. Controles tradicionais continuam válidos: inventário, acesso, validação, monitoramento, testes, governança, minimização e resposta.

14.3 Segurança física e ambiental

Ameaças físicas incluem acesso não autorizado, furto, incêndio, água, calor e perda de energia. Controles combinam zonas, identificação, registro de visitantes, detecção, climatização, UPS, gerador e descarte seguro. A segurança lógica pode falhar se alguém retirar um disco não criptografado ou conectar equipamento à rede interna.

15. Como o ENADE avalia Segurança da Informação

O ENADE apresenta situações-problema, afirmações e alternativas que exigem integrar conceitos. A estratégia mais segura é separar cada proposição, identificar o princípio técnico testado, procurar termos absolutos e só então combinar as verdadeiras.

12. Leia o comando e marque se pede correta, incorreta ou combinação.
13. Traduza o cenário em ativo, ameaça, vulnerabilidade, impacto e controle.
14. Julgue cada afirmação sem olhar primeiro as combinações.
15. Verifique se o controle atua sobre a causa alegada.
16. Elimine confusões clássicas: autenticação versus autorização; hash versus cifragem; redundância versus backup; anonimização versus pseudonimização.
17. Confirme a combinação e revise o enunciado.

15.1 Questão 15 do ENADE 2017

Tema: ataque de homem no meio por ARP spoofing em rede Wi-Fi. Gabarito oficial: D, correspondente às afirmações I, III e IV.

Afirmação	Julgamento	Justificativa
I Uso de protocolo com chave pública para negociar chaves individuais, como TLS	Verdadeira	A autenticação criptográfica e a negociação segura ajudam a impedir que o intermediário estabeleça sessões confiáveis sem ser detectado.
II Firewall no ponto de acesso evita o desvio entre clientes da mesma sub-rede	Falsa	Firewall genérico não corrige necessariamente o envenenamento ARP. O problema exige controles de camada 2, autenticação e proteção fim a fim.
III Certificado do ponto de acesso autenticável com chave pública confiável	Verdadeira	Certificados podem vincular identidade e chave quando a cadeia é validada.
IV Substituir chaves fracas por 128 bits e limitar dispositivos compatíveis	Verdadeira no contexto da questão	Aumentar a força criptográfica e impedir modos legados reduz a vulnerabilidade de força bruta descrita no item.

Aprendizado Não escolha um controle apenas porque ele "é de segurança". Relacione mecanismo e causa. ARP spoofing ocorre na

resolução local IP–MAC; TLS limita o que um intermediário consegue ler ou alterar, mas não impede sozinho a falsificação ARP.

15.2 Questão 16 do ENADE 2017

Tema: segurança como processo, fator humano, engenharia social e ética. Gabarito oficial: E, com as três afirmações consideradas corretas.

Afirmação	Leitura
I Organizações permanecem vulneráveis diante do fator humano	O sentido cobrado é que controles técnicos não eliminam riscos de comportamento e manipulação. Em prática profissional, evite tratar pessoas como causa única.
II Segurança da Informação é processo, não produto	Correta: riscos, ativos, ameaças e tecnologia mudam; controles exigem ciclo de gestão e melhoria.
III Ética profissional é relevante	Correta: profissionais possuem acesso privilegiado, tomam decisões e devem considerar deveres, impactos e responsabilidade.

15.3 Questão 12 do ENADE 2021

Tema: LGPD. Gabarito oficial: B, correspondente às afirmações I e III.

Afirmação	Julgamento	Justificativa
I A lei restringe tratamento indiscriminado de dados sensíveis	Verdadeira	Dados sensíveis recebem regime específico e exigem hipótese legal e salvaguardas.
II Dados anonimizados nunca são pessoais mesmo se a anonimização puder ser revertida	Falsa	Se a associação puder ser revertida por meios próprios ou esforços razoáveis, a exclusão do regime de dado pessoal não é automática.
III Titular pode confirmar tratamento e pedir correção ou eliminação nas condições legais	Verdadeira	A LGPD prevê direitos do titular; a eliminação depende do contexto e das exceções legais.
IV ANPD fiscaliza, regula e modifica a legislação	Falsa	A Autoridade regulamenta e fiscaliza em sua competência, mas alteração de lei depende do processo legislativo.

15.4 Questão 24 do ENADE 2021

Tema: criptografia de ponta a ponta. Gabarito oficial: E, correspondente às afirmações I, II e IV.

Afirmação	Julgamento	Justificativa
I Chave pública do remetente permite verificar autenticidade de assinatura	Verdadeira	A verificação funciona se a chave pública estiver corretamente vinculada ao remetente e o protocolo usar assinatura adequada.

II IV variável oculta padrões e pode contribuir contra repetição no protocolo descrito	Verdadeira no contexto	Variação por mensagem evita resultados repetidos; proteção contra replay também depende de estado, contadores ou autenticação do protocolo.
III AES é simétrico porque usa um par de chaves diferentes	Falsa	AES é simétrico: a mesma chave secreta é usada para cifrar e decifrar. Par pública/privada caracteriza criptografia assimétrica.
IV SHA-256 pode detectar alteração pela comparação de resumos	Verdadeira com ressalva	Hash detecta mudança acidental ou quando o valor esperado é confiável. Contra atacante ativo, usa-se MAC ou assinatura para autenticar o resumo.

16. Quadros de revisão rápida

16.1 Confusões frequentes

Não confunda	Diferença essencial
Ameaça e vulnerabilidade	A ameaça pode causar dano; a vulnerabilidade é a fraqueza explorável.
Risco e incidente	Risco é possibilidade e impacto; incidente é ocorrência que compromete ou ameaça.
Identificação e autenticação	Identificar é declarar identidade; autenticar é prová-la.
Autenticação e autorização	Autenticar confirma quem; autorizar decide o que pode.
Hash e criptografia	Hash é unidirecional; cifragem é reversível com chave.
Assinatura e cifragem	Assinatura protege autenticidade e integridade; cifragem protege confidencialidade.
Backup e redundância	Backup recupera estado anterior; redundância mantém serviço diante de falha.
Anonimização e pseudonimização	Anonimização efetiva rompe associação razoável; pseudonimização mantém possibilidade com informação adicional.
Privacidade e segurança	Privacidade governa tratamento justo e proporcional; segurança protege contra eventos adversos.
Vulnerabilidade e exploit	Vulnerabilidade é fraqueza; exploit é meio de explorá-la.

16.2 Escolha do controle pelo objetivo

Objetivo	Controle mais relacionado	Limite
Ocultar conteúdo em repouso	Criptografia de disco ou campo	Não impede leitura por aplicação autorizada comprometida
Detectar mudança	Hash autenticado ou assinatura	Hash simples não identifica autor
Confirmar identidade	Autenticação proporcional ao risco	Recuperação fraca pode contornar MFA
Reduzir movimento lateral	Segmentação e privilégio mínimo	Regras mal mantidas criam exceções

Recuperar após ransomware	Backup isolado e restauração testada	Cópia online pode ser cifrada junto
Prevenir injeção SQL	Consulta parametrizada	Autorização ainda precisa ser verificada
Atender necessidade da LGPD	Minimização e base legal adequada	Consentimento não é a única base

16.3 Fórmulas e relações úteis

Disponibilidade simplificada A = MTBF ÷ (MTBF + MTTR). O modelo serve para exercícios, mas sistemas reais podem ter manutenção planejada, falhas correlacionadas e dependências externas.

Risco qualitativo Risco = função de probabilidade e impacto. Multiplicar escalas de 1 a 5 é ferramenta de priorização e exige critérios explícitos.

Privilégio efetivo Permissões concedidas por vários papéis e grupos podem se somar. Revise o acesso efetivo, não apenas o papel nominal.

Checklist final

- Consigo explicar CIA com exemplos e limites.
- Distingo ativo, ameaça, vulnerabilidade, risco, evento, incidente e controle.
- Comparo cifra simétrica, assimétrica, hash, HMAC e assinatura.
- Distingo identificação, autenticação, autorização e auditoria.
- Relaciono ataques de rede aos controles corretos.
- Aplico segurança ao sistema operacional, software, banco, API e nuvem.
- Defino RPO, RTO e teste de restauração.
- Explico funções do NIST CSF 2.0 e ciclo de resposta.
- Aplico princípios, conceitos e direitos da LGPD.
- Consigo justificar por que cada afirmação das quatro questões oficiais é verdadeira ou falsa.

Referências

Materiais fornecidos

BRASIL. Instituto Nacional de Estudos e Pesquisas Educacionais Anísio Teixeira. Prova do ENADE 2017 — Ciência da Computação, Bacharelado. Brasília, DF: Inep, 2017.
BRASIL. Instituto Nacional de Estudos e Pesquisas Educacionais Anísio Teixeira. Gabarito definitivo do ENADE 2017 — Ciência da Computação, Bacharelado. Brasília, DF: Inep, 2017.
BRASIL. Instituto Nacional de Estudos e Pesquisas Educacionais Anísio Teixeira. Prova do ENADE 2021 — Ciência da Computação, Bacharelado. Brasília, DF: Inep, 2021.
BRASIL. Instituto Nacional de Estudos e Pesquisas Educacionais Anísio Teixeira. Gabarito definitivo do ENADE 2021 — Ciência da Computação, Bacharelado. Brasília, DF: Inep, 2022.
RELATÓRIO DE PESQUISA — ENADE E CIÊNCIA DA COMPUTAÇÃO. Material de síntese fornecido pela estudante, 2026.

Fontes oficiais complementares

BRASIL. Conselho Nacional de Educação. Resolução CNE/CES nº 5, de 16 de novembro de 2016. Institui as Diretrizes Curriculares Nacionais para os cursos de graduação na área da Computação. Disponível em: https://www.gov.br/mec/pt-br/cne/pdf/normas-classificadas-por-assunto/diretrizes-curriculares-cursos-de-graduacao/rces005_16.pdf . Acesso em: 21 set. 2026.
BRASIL. Instituto Nacional de Estudos e Pesquisas Educacionais Anísio Teixeira. Portaria nº 401, de 23 de agosto de 2021. Diretrizes de prova do ENADE 2021 para Ciência da Computação. Disponível em: https://www.gov.br/inep/pt-br/centrais-de-conteudo/legislacao/enade/2021 . Acesso em: 21 set. 2026.
BRASIL. Lei nº 13.709, de 14 de agosto de 2018. Lei Geral de Proteção de Dados Pessoais. Texto compilado. Disponível em: https://www.planalto.gov.br/ccivil_03/_ato2015-2018/2018/lei/L13709compilado.htm . Acesso em: 21 set. 2026.
AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Guia orientativo sobre segurança da informação para agentes de tratamento de pequeno porte. Brasília, DF: ANPD, 2021. Disponível em: https://www.gov.br/anpd/pt-br/documentos-e-publicacoes/guia-vf.pdf . Acesso em: 21 set. 2026.
AUTORIDADE NACIONAL DE PROTEÇÃO DE DADOS. Materiais educativos e publicações. Disponível em: https://www.gov.br/anpd/pt-br/centrais-de-conteudo/materiais-educativos-e-publicacoes . Acesso em: 21 set. 2026.
CISA. Secure by Design. Washington, DC, 2023. Disponível em: https://www.cisa.gov/sites/default/files/2023-10/SecureByDesign_1025_508c.pdf . Acesso em: 21 set. 2026.
CISA. Multifactor Authentication. Disponível em: https://www.cisa.gov/topics/cybersecurity-best-practices/multifactor-authentication . Acesso em: 21 set. 2026.
IETF. RFC 9846: The Transport Layer Security Protocol Version 1.3. RFC Editor, 2026. Disponível em: https://www.rfc-editor.org/info/rfc9846/ . Acesso em: 21 set. 2026.
ISO. ISO/IEC 27001:2022 — Information security management systems — Requirements. Genebra: ISO, 2022. Disponível em: https://www.iso.org/standard/27001 . Acesso em: 21 set. 2026.

ISO. ISO/IEC 27005:2022 — Guidance on managing information security risks. Genebra: ISO, 2022. Disponível em: https://www.iso.org/standard/80585.html . Acesso em: 21 set. 2026.
NIST. The Cybersecurity Framework 2.0. Gaithersburg, 2024. Disponível em: https://www.nist.gov/publications/nist-cybersecurity-framework-csf-20 . Acesso em: 21 set. 2026.
NIST. SP 800-30 Rev. 1 — Guide for Conducting Risk Assessments. Gaithersburg, 2012. Disponível em: https://csrc.nist.gov/pubs/sp/800/30/r1/final . Acesso em: 21 set. 2026.
NIST. SP 800-53 Rev. 5 — Security and Privacy Controls for Information Systems and Organizations. Atualização 1. Disponível em: https://csrc.nist.gov/pubs/sp/800/53/r5/upd1/final . Acesso em: 21 set. 2026.
NIST. SP 800-61 Rev. 3 — Incident Response Recommendations and Considerations for Cybersecurity Risk Management. Gaithersburg, 2025. Disponível em: https://csrc.nist.gov/pubs/sp/800/61/r3/final . Acesso em: 21 set. 2026.
NIST. SP 800-63-4 — Digital Identity Guidelines. Gaithersburg, 2025. Disponível em: https://csrc.nist.gov/pubs/sp/800/63/4/final . Acesso em: 21 set. 2026.
NIST. SP 800-207 — Zero Trust Architecture. Gaithersburg, 2020. Disponível em: https://csrc.nist.gov/pubs/sp/800/207/final. Acesso em: 21 set. 2026.
NIST. SP 800-218 — Secure Software Development Framework Version 1.1. Gaithersburg, 2022. Disponível em: https://csrc.nist.gov/pubs/sp/800/218/final . Acesso em: 21 set. 2026.
NIST. FIPS 197 — Advanced Encryption Standard. Atualização editorial. Gaithersburg, 2023. Disponível em: https://csrc.nist.gov/pubs/fips/197/final . Acesso em: 21 set. 2026.
NIST. FIPS 180-4 — Secure Hash Standard. Gaithersburg, 2015. Disponível em: https://csrc.nist.gov/pubs/fips/180-4/upd1/final . Acesso em: 21 set. 2026.
OWASP FOUNDATION. OWASP Top 10:2025. Disponível em: https://owasp.org/Top10/2025/pt-BR/ . Acesso em: 21 set. 2026.